

AD LAB: ARCHITECTURE & COMPROMISE REPORT

Target Difficulty: Medium

Date: December 26, 2025

1. INFRASTRUCTURE & ARCHITECTURE

This lab simulates a realistic enterprise Active Directory environment featuring a multi-domain forest (Parent-Child topology). The environment allows for lateral movement, privilege escalation via ACL abuse, and forest dominance via advanced Kerberos attacks.

1.1 Network Inventory

The network consists of three primary nodes. The attack path begins in the DEV child domain and moves upward to the CORP forest root.

IP Address	Hostname	Role	OS	Domain
10.10.10.10	DC-CORP	Parent Domain Controller	Windows Server 2019	corp.local
10.10.10.20	DC-DEV	Child Domain Controller / CA	Windows Server 2019	dev.corp.local
10.10.10.30	APP01	Application / SQL Server	Windows Server 2019	dev.corp.local

1.2 Identity & Access Management (Credentials)

Below are the predefined credentials for the environment. Note that high-value passwords are intentionally complex to force specific exploit paths (e.g., AD CS or Golden Ticket) rather than brute-forcing.

IP Address / Scope	Username	Password	Role / Notes
10.10.10.10 (Parent)	Administrator	Password123!	Parent Domain Admin (Target of Golden Ticket)
10.10.10.20 (Child)	Administrator	'6738hHF*#HF#(FJAJF#(@)CMA)'	Child Domain Admin (Obtained via AD CS)
10.10.10.20 (Child)	JSmith	Winter2025!@#ResetAll	Standard User (Found in db_backup.ps1)
10.10.10.30 (App)	sql_svc	1941.Salembbb.41	Service Account (Cracked via NTLM Capture)
10.10.10.20 (Child)	IT_Admin	Summer2025!Complex	Target Account (Reset via ACL Abuse)

1.3 Vulnerability Landscape (The Kill Chain)

- MSSQL xp_dirtree (Initial Access):** The SQL Server on 10.10.10.30 allows the guest user to execute xp_dirtree, forcing an authentication request to an attacker-controlled SMB share. This leaks the NTLMv2 hash of the service account (sql_svc).
- Information Disclosure:** A PowerShell script (db_backup.ps1) left on the sql_svc user's file system contains the cleartext password for JSmith.

3. **ACL Abuse (Lateral Movement):** JSmith has been granted the specific Active Directory permission to **Force Password Change** on the IT_Admin user, allowing account takeover without knowing the previous password.
 4. **AD CS ESC1 (Privilege Escalation):** The Certificate Authority on 10.10.10.20 has a misconfigured template (ESC1_Template). It allows low-privileged users (IT_Admin) to request a certificate for **any** user (including Administrator) by specifying a Subject Alternative Name (SAN).
 5. **SID History Injection (Forest Dominance):** Once the Child Domain is compromised, the attacker can forge a Golden Ticket with the Enterprise Admin SID (-519) to compromise the Parent Domain Controller across the trust boundary.
-